SafeDB-CI

Production-Grade Database Migration Validator

Comprehensive Technical Report

Team Members:

Ajay M Nambiar (TLY23CS014)

Akhinith P (TLY23CS015)

Arjun D (TLY23CS033)

Aswin Ganga (TLY23CS037)

Faculty Advisor:

Nikhil Dharman M K

Asst. Professor, Dept of Computer Science Engineering

College Of Engineering Thalassey

March 18, 2026

Contents

Abstract **5**

1 Introduction **6**
1.1 Background and Motivation 6
1.2 The Role of Database Orchestration in CI 6
1.3 Formal Definition of SafeDB-CI 7
1.4 Scope and Objectives 7

2 Problem Statement **9**
2.1 Destructive Operation Blindspots 9
2.2 Schema Tampering and State Drift 9
2.3 Dangling Schema Relationships and Relational Integrity 10
2.4 Implicit Auto-Commit Instability in MySQL 10
2.5 The Absolute Necessity for Pre-merge Validation 10

3 Solution Approach: The 8-Phase Validation Pipeline **11**
3.1 Phase 1: Lexical Ordering Verification (`versioning.py`) 12
3.2 Phase 2: Cryptographic Tamper Locking (`lockfile.py`) 12
3.3 Phase 3: Intent-based Static Analysis (`safety.py`) 12
3.4 Phase 4: Ephemeral Simulation and Dry-Runs (`executor.py`) 13
3.5 Phase 5: Native Schema Introspection (`schema.py`) 13
3.6 Phase 6: Structural Verification against the Snapshot 13
3.7 Phase 7: Lexical Naming Heuristics (`naming.py`) 14
3.8 Phase 8: Artifact Generation and Lockfile Write 14

4 Technology Stack **15**
4.1 Core Programming Language: Python 3.11+ 15
4.2 Database Integration Adapters 15
4.3 Continuous Integration Environment: GitHub Actions 16

5 Software Requirements Specification **17**
5.1 Introduction 17
5.1.1 1.1 Purpose 17
5.1.2 1.2 Scope 17
5.1.3 1.3 Definitions, Acronyms, and Abbreviations 17
5.1.4 1.4 References 17
5.2 Overall Description 18
5.2.1 2.1 Product Perspective 18

5.2.2 2.2 Product Functions . . . 18
5.2.3 2.3 User Characteristics . . . 19
5.2.4 2.4 Constraints . . . 19
5.3 Specific Requirements . . . 20
5.3.1 3.1 External Interface Requirements . . . 20
5.3.2 3.2 Functional Requirements . . . 20
5.3.3 3.3 Performance Requirements . . . 20
5.3.4 3.4 Logical Database Requirements . . . 20
5.3.5 3.5 Software System Attributes . . . 21

6 System Design Document **22**
6.1 1. Introduction . . . 22
6.2 2. System Overview . . . 22
6.3 3. System Architecture . . . 22
6.3.1 3.1 Data Flow Topology . . . 23
6.4 4. Logical Data Design . . . 24
6.4.1 4.1 The SchemaSnapshot Definition . . . 24
6.5 5. Component Level Design . . . 25
6.5.1 5.1 The CLI Orchestrator (`engine/cli.py`) . . . 25
6.5.2 5.2 Cryptographic Boundaries (`lockfile.py`) . . . 25
6.5.3 5.3 Introspection Core (`schema.py`) . . . 25

7 Test Plan & Execution Matrices **26**
7.1 Objective Coverage . . . 26
7.2 Methodologies . . . 26
7.2.1 Core Utility Testing (Unit Bounds) . . . 26
7.3 End-to-End Docker Integration Arrays . . . 26
7.4 Test Case Specifications . . . 27

8 Development, Coding, and Continuous Quality Testing **29**
8.1 Development Methodology and Lifecycle . . . 29
8.1.1 Object-Oriented Isolation . . . 29
8.2 Testing Automation and Iteration . . . 29
8.2.1 The Examples Directory Test Suites . . . 29
8.3 Dog-fooding and Self-Evaluation . . . 30

9 Deployment Architecture **31**
9.1 Native GitHub Actions Lifecycle (`action.yml`) . . . 31
9.2 Standalone Orchestration and Local Developer Hooks . . . 32

10 System Output Arrays and Test Results **33**
10.1 The JSON Reporting Layer (`reporter.py`) 33
10.2 Native GitHub Step Summary Traces 34
10.3 Terminal Output and POSIX Exit Handlers 34

11 Conclusion and Future Scope **35**
11.1 Rigorous Conclusion Summaries 35
11.2 Operational Extensions & Future Research Scope 35

Glossary of Core Terms **37**

List of Figures

1 8-Phase Validation Pipeline Data Flow 11
2 SafeDB-CI Use Case Diagram 19
3 System Architecture Diagram 23

Abstract

Database migrations act as the critical bridge mapping volatile software models to durable physical schemas, yet modern CI/CD pipelines routinely lack the depth to verify these transformations beyond simple syntax checks. **SafeDB-CI** introduces a paradigm-shifting tool engineered to enforce rigorous structural integrity throughout the deployment lifecycle by protecting both PostgreSQL and MySQL platforms. Leveraging a sophisticated 8-phase validation architecture, SafeDB-CI operates on principles of strict ordering validations, tamper-resistant lockfiles, static SQL safety scans, isolated real-time executions, and post-execution internal catalog reflections. By deterministically shifting database validation radically left in the CI sequence, SafeDB-CI acts as an impenetrable guardrail, autonomously securing production databases against destructive DDL behaviors and broken relational constraints.

1. Introduction

1.1. Background and Motivation

In high-velocity software delivery architectures, the conceptual gap between verifying application logic and database transformations remains paradoxically wide. Modern software engineering heavily relies on Agile methodologies, Continuous Integration (CI), and Continuous Deployment (CD). These paradigms require developers to merge code multiple times a day, backed by an extensive suite of automated unit, integration, and end-to-end tests. A standard CI environment effortlessly provisions micro-testing clusters capable of capturing microscopic logical inconsistencies across highly volatile domains like Python, Node.js, or Java.

Yet, when evaluating structured query language (SQL) changes—the exact commands responsible for extending and mutating these logic pathways toward permanent physical disk states—typical DevOps methodologies inexplicably regress. The ubiquitous standard operation across the industry remains simply executing migration sets against a blank, ephemeral container (often a vanilla Docker image of PostgreSQL or MySQL). Upon achieving zero syntax collisions and avoiding out-of-bounds runtime crashes, pipeline systems yield a highly dangerous false narrative of structural safety.

Because migration endpoints inherently represent a transformation of preexisting data—not just empty structure definitions—an execution succeeding against an empty database presents an inherently incomplete picture. Destructive events, specifically operations unconditionally dropping historical table structures, intentionally deleting crucial rows without `WHERE` clauses, or cascading deletions against heavily linked production schemas, slip silently into critical environments.

1.2. The Role of Database Orchestration in CI

The concept of database orchestration revolves around the idea of treating database schema changes exactly like application code—versioned, peer-reviewed, and continuously integrated. Tools like Flyway and Liquibase have successfully standardized the application of migrations, tracking which files have been run and which are pending. However, these tools operate as execution engines rather than analytical safety nets. They blindly execute the instructions provided developers, operating on the assumption that the developer has thoroughly vetted the mathematical and structural integrity of the command.

This assumption breaks down under the scale and speed of modern software delivery. A developer might accidentally include a `DROP TABLE` command intended for a local testing environment in a commit destined for the production branch. Without an automated,

intelligent intermediary analyzing the semantic intent of the SQL prior to physical execution, the CI pipeline becomes a weapon of mass data destruction rather than a protective shield.

1.3. Formal Definition of SafeDB-CI

To address this critical security and stability vacuum, **SafeDB-CI** was conceptualized and engineered. SafeDB-CI serves as the definitive shift-left paradigm specifically targeting structural persistence. Functioning both as a streamlined GitHub Composite Action—seamlessly dropping into any modern repository with minimal configuration—and an independent orchestration CLI written in modern Python (3.11+), SafeDB-CI statically and dynamically validates data operations through a highly sophisticated, deterministic eight-phase progression.

Transcending simple syntax linting, SafeDB-CI operates as a robust relational watchdog. It maps explicit operational bounds ensuring version chronologies lock natively via cryptographic hashing (SHA-256), thereby preventing downstream pipeline tampering where historical files might be invisibly altered locally. Most significantly, it derives genuine runtime safety not through abstract parsing alone, but via an introspection engine actively evaluating actual internal dictionary catalog state graphs for MySQL and PostgreSQL natively. It mathematically proves relational schema health, validating that all foreign keys map perfectly to guaranteed unique external constraints, before ever greenlighting a feature branch for a production merge.

1.4. Scope and Objectives

The primary objective of this project is to construct an autonomous, zero-trust database validation gatekeeper. The system is designed to:

1. Intercept and halt any Data Definition Language (DDL) or Data Manipulation Language (DML) script that exhibits destructive properties.
2. Prevent schema drift by detecting historical file alterations via strict lockfile cryptography.
3. Identify structural anomalies, such as broken foreign key relationships and missing primary constraints, by introspecting the database engine's internal catalog post-execution.
4. Provide comprehensive JSON and Markdown reporting directly into the GitHub Actions step summary UI.
5. Guarantee cross-compatibility with the specific, often conflicting, behaviors of PostgreSQL 12+ and MySQL 8+ (specifically InnoDB).

By accomplishing these objectives, SafeDB-CI radically transforms database lifecycle management from a reactive, error-prone human endeavor into a proactive, strictly enforced mathematical certainty.

2. Problem Statement

The core vulnerability inherent within traditional data deployment strategies lies in relying stringently upon structural syntax execution to quantify absolute safety. SafeDB-CI identifies, categorizes, and systematically resolves several critical infrastructure gaps that regularly compromise enterprise-grade database integrity.

2.1. Destructive Operation Blindspots

In a typical continuous integration setup, a shell script spins up a database, runs `psql` or `mysql` to execute a series of `.sql` files, and checks the exit code. If the exit code is `0`, the build passes. This simplistic automation inadvertently greenlights perfectly formatted malicious or destructive SQL.

An intentional or accidental execution of a `TRUNCATE` command, a `DROP TABLE` instruction, or an unconditional full-table `DELETE FROM` operation will annihilate gigabytes of live production histories. Because these commands are valid SQL, they execute flawlessly against the empty, ephemeral database in the CI environment without triggering syntax errors. The development team remains completely unaware of the destructive payload until it hits the production server, at which point the damage is instantaneous and catastrophic, requiring massive downtime and complex point-in-time recovery (PITR) procedures.

2.2. Schema Tampering and State Drift

Database migration states are inextricably tied to their chronological execution order. If developer A commits a migration file named `001_create_users.sql`, and developer B independently creates `002_add_email.sql`, the database builds sequentially.

However, in dense developer environments involving rebasing, detached `HEAD` states, and complex merge conflict resolutions, a developer might casually alter the historical `001_create_users.sql` file locally to add a new column, rather than creating a proper `003_add_new_column.sql` file. This action implicitly rewrites the database timeline history locally. When merged, the CI pipeline re-executes everything successfully from scratch. But the production database, which already executed the original `001` file months ago, is now permanently out of sync with the source code repository. These tampered files inevitably corrupt deployment mappings, causing massive friction and manual intervention delays during subsequent deployments.

2.3. Dangling Schema Relationships and Relational Integrity

Relational databases predicate their integrity strictly on the enforcement of mathematical constraints—primarily Foreign Keys (FK) linking to Primary Keys (PK) or Unique constraints. Developers frequently introduce migration files that attempt to link a foreign key toward an entity structure that does not yet exist, or structure a foreign key directly against a column that is not strictly enforced as unique.

In highly permissive database environments, or when utilizing specific legacy schema structures, improper cross-linking mapping against unverified non-unique column metrics corrupts relational integrity entirely. These silent structural failures do not necessarily crash the migration sequence immediately. Instead, they lie dormant until a specific application edge-case routing triggers an insertion or deletion failure late within the runtime environment, resulting in bewildering `IntegrityError` 500-level HTTP responses to end-users.

2.4. Implicit Auto-Commit Instability in MySQL

Database vendors implement fundamentally different philosophies regarding transaction scope around Data Definition Language (DDL) statements. PostgreSQL executes DDL transparently behind explicitly stated `BEGIN` and `COMMIT` transaction blocks. If a script creates two tables and fails on the third, PostgreSQL effortlessly triggers a flawless `ROLLBACK`, resetting the database exactly to its pristine conceptual state.

Contrastingly, MySQL aggressively asserts implicit auto-commits immediately sandwiching DDL mappings. If multiple `CREATE` or `ALTER` operations exist within a single migration script executed against a MySQL InnoDB engine, and the script fails halfway through due to a syntax error, the preceding operations are already permanently committed to the disk. They cannot be rolled back. This leaves the database environment in an irrecoverable, partial schema fragment state, polluting production indefinitely and requiring manual drop commands to reset. Traditional CI pipelines lack the sophisticated awareness required to handle this stark environmental dichotomy.

2.5. The Absolute Necessity for Pre-merge Validation

The synthesis of these vulnerabilities proves that reactive runtime checks are insufficient. DevOps architectures mandate deterministic validation tools extending past runtime checks into analytical semantic intent detection and relational mathematical profiling natively before branch merging pathways initiate. SafeDB-CI is constructed precisely to address this vacuum, identifying these exact problem vectors mathematically and terminating the pipeline forcefully to preserve production sanity.

3. Solution Approach: The 8-Phase Validation Pipeline

To systematically dismantle the complex migration risk topologies outlined in the problem statement without encumbering developer velocity, SafeDB-CI architects a continuous delivery enforcement engine heavily structured around its core algorithmic orchestrator (`engine/cli.py`). Instead of relying on generalized shell-script bounds, operations cascade exclusively through a strictly formalized 8-Phase Guardrail Pipeline. This deterministic pipeline resolves edge-case parameters actively, analyzing intent, execution, and resultant mathematical state.

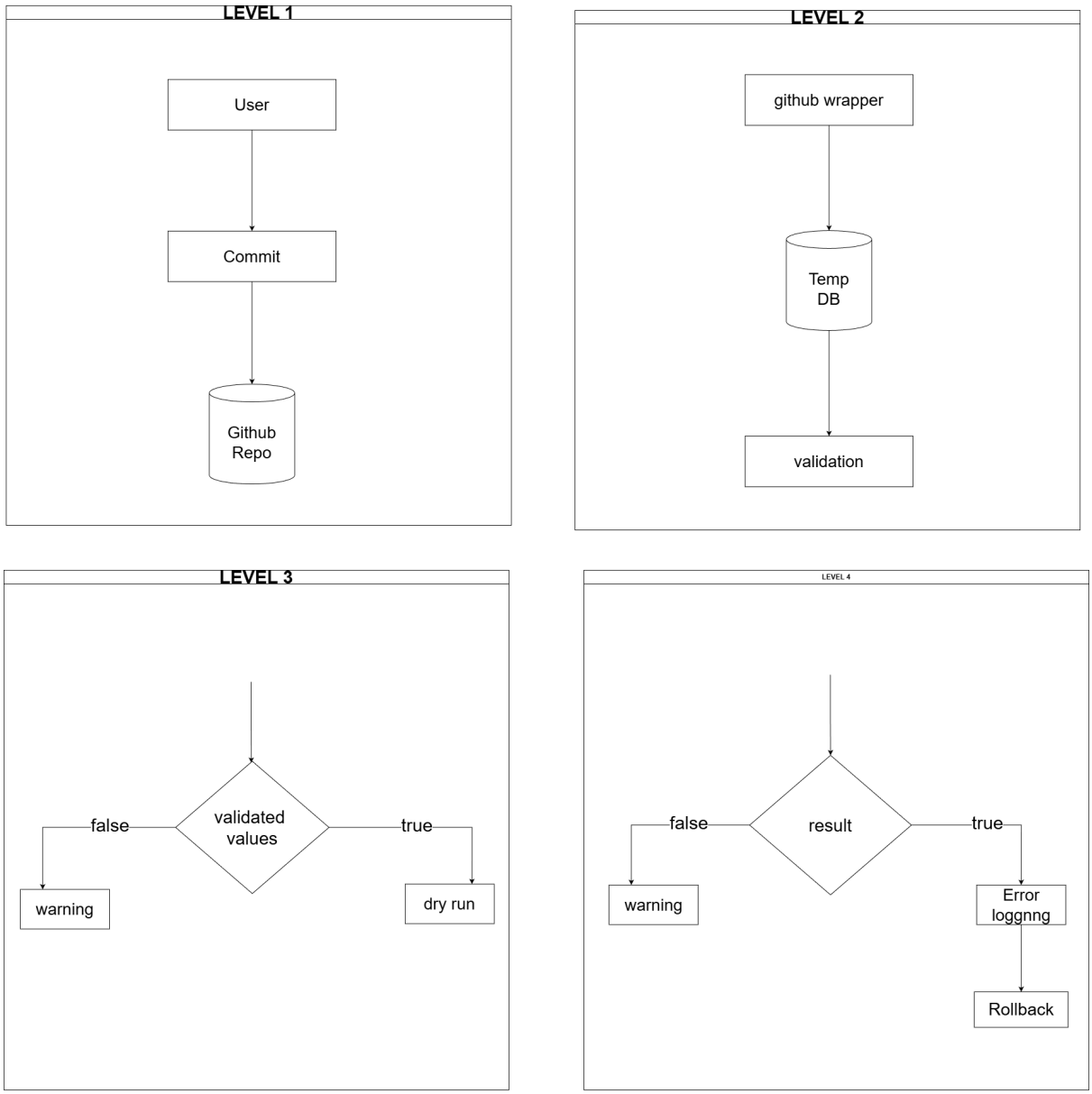

Figure 1: 8-Phase Validation Pipeline Data Flow

3.1. Phase 1: Lexical Ordering Verification (`versioning.py`)

The initial phase acts as a strict filesystem sanitizer. The validation engine explicitly loads the target directory containing the SQL files. It parses the files expecting a chronologically nested prefix adhering to the standard `NNN_description.sql` format (e.g., `001_init.sql`, `002_update.sql`). The engine algorithmically extracts the integer prefixes, sorting them mathematically. It actively hunts for specific chronological violations:

- **Gaps:** Overlooked merges representing missing sequence files (e.g., jumping from `002` directly to `004`) are flagged critically, preventing discontinuous logic loops.
- **Collisions:** Duplicate versionings (e.g., two developers simultaneously merging different `005_.sql` files) throw an immediate ‘SequenceCollisionError‘, forcing developer conflict resolution before proceeding.

3.2. Phase 2: Cryptographic Tamper Locking (`lockfile.py`)

To solve the schema drift problem, Phase 2 implements a persistent local checksum database via a `.safedb-lock` JSON file. Upon evaluating the targeted `.sql` files, the module natively generates an exhaustive SHA-256 cryptographic binding per file representing its exact byte-content state. The system algorithmically performs an intersection mapping between the currently calculated hashes and the hashes permanently bound inside the committed lockfile. If the validation identifies that a post-validation hash has invisibly altered its historical mapping, an immediate **TAMPER DETECTED** cascade permanently blocks the CI. This guarantees that historical timeline immutability remains permanently unviolated.

3.3. Phase 3: Intent-based Static Analysis (`safety.py`)

Prior to ever instantiating a socket connection to the targeted database engine, SafeDB-CI passes the raw text mappings of every migration file through massive Regex abstract matrices statically. This phase determines the absolute conceptual ”intent” of the code.

- **HIGH Severity Rules:** The system parses operations for destructive bounds. Keywords targeting `DROP TABLE`, unconditional `DELETE FROM` instances mapping no `WHERE` clauses, and `TRUNCATE` bounds immediately halt validation execution, ejecting status code ‘1‘ cleanly.
- **MEDIUM Severity Rules:** Potentially dangerous bounds matching statements like `ALTER COLUMN TYPE` and `SET NOT NULL` throw explicit CI warnings natively. If the pipeline operates utilizing the `--strict` flag toggle, these warnings immediately escalate into pipeline-terminating failures.

- **Controlled Exceptions:** Recognizing extreme edge-cases where destruction is genuinely intended, developers can conditionally bypass known exceptions via explicit line-annotated `-- safedb:allow` bounds, creating strict audit trails that security teams can monitor exclusively.

3.4. Phase 4: Ephemeral Simulation and Dry-Runs (`executor.py`)

Leveraging dynamically injected target strings, the SQL operations finally execute cleanly across ephemeral sandboxed bounds. Supported uniquely is the crucial `--dry-run` mode mapping natively against PostgreSQL adapters. By encapsulating the entire execution chain natively within an explicit `BEGIN` and terminal `ROLLBACK` loop, the engine seamlessly invokes the database to syntax-check and structural-check the entire deployment script completely in real-time, validating memory parameters perfectly without ever committing structural state changes to the physical disk structures.

3.5. Phase 5: Native Schema Introspection (`schema.py`)

Traditional migration validators cease operation following successful execution. SafeDB-CI, contrastingly, initiates its deepest algorithmic functions here. Instead of attempting to parse the SQL locally to guess what the schema looks like, the validation engine dives immediately into the native internal system catalogs. It constructs massive queries against PostgreSQL's `information_schema.columns` mapping against `key_column_usage`, and equivalent MySQL system tables. These queries cross-join tables isolating column sizes, primary key topological maps, and complex foreign key constraint origins. The application then normalizes these uniquely formatted data layers into an abstracted, database-agnostic Python memory model known as the `SchemaSnapshot`.

3.6. Phase 6: Structural Verification against the Snapshot

The derived `SchemaSnapshot` actively flows through deterministic mathematical protection guards:

- **Target Verification:** Ensuring `FOREIGN KEY` structures perfectly target existing entities implicitly. Linkages referencing tables or columns not present in the Snapshot crash the CI deterministically.

- **Uniqueness Mapping:** The rule engine asserts that a `FOREIGN KEY` may exclusively reference targets officially protected by `UNIQUE` or `PRIMARY KEY` endpoints, terminating any weak relational mapping.

- **Constraint Duplication Base:** Assuring duplicate constraint layers mapping identical functional boundaries aren't repeatedly overloading DB catalogs wastefully.

3.7. Phase 7: Lexical Naming Heuristics (`naming.py`)

Enforcing enterprise operational consistency natively ensures all tables and column derivations follow strict stylistic templates, identifying non-standardized structures programmatically (e.g., verifying `snake_case` naming conventions universally).

3.8. Phase 8: Artifact Generation and Lockfile Write

Successfully verified pipelines natively execute mathematical hashes binding updated source states back toward the `.safedb-lock` natively. Furthermore, a deep JSON execution report and native `GITHUB_STEP_SUMMARY` emit standardized analytical metrics representing the complete operational trace of the system, defining pipeline health natively across reporting dashboards.

4. Technology Stack

SafeDB-CI is constructed using a modern, rigorously tested technology stack carefully selected to balance high-performance execution speed with stringent type safety and cross-platform reliability.

4.1. Core Programming Language: Python 3.11+

The entire orchestration and validation engine is developed in Python 3.11+. The decision to leverage Python was driven by its unparalleled text processing capabilities and its massive ecosystem of database driver bindings.

- **Advanced Type Hinting (`PEP-484` and `PEP-589`):** The codebase strictly enforces static type analysis. By utilizing `TypedDict`, `Literal`, and standard generic collections, the orchestrator guarantees that data structures—such as the nested JSON reports or the `SchemaSnapshot` bindings—are mathematically sound before runtime. This eliminates entire classes of `TypeError` and `AttributeError` tracebacks that plague dynamic languages.

- **Dataclasses (`PEP-557`):** Internal structures, particularly the representation of database columns (`ColumnInfo`), tables (`TableSchema`), and relational keys (`ForeignKeyInfo`), are managed entirely via frozen `@dataclass(frozen=True)` decorators. This ensures that once the schema introspection phase records the state of the database, the memory map becomes completely immutable, preventing accidental internal mutation during the validation phase.

- **Advanced Regular Expressions (`re`):** The static intent analysis phase (Phase 3) relies on pre-compiled Python Regex engines. Unlike traditional linear string matching, the Python `re` module effectively handles positive and negative lookarounds, allowing SafeDB-CI to detect a `DROP TABLE` command while simultaneously ignoring it if embedded within a SQL block comment.

4.2. Database Integration Adapters

SafeDB-CI abstracts its database interactions through a normalized `DatabaseAdapter` interface, allowing identical CI logic to govern vastly different SQL engines.

- **PostgreSQL (`psycopg`):** SafeDB-CI natively supports PostgreSQL 12 through 16 using the highly performant `psycopg` driver. PostgreSQL is uniquely suited for the tool's `--dry-run` simulations because it supports fully encapsulated DDL transactions. The adapter explicitly issues a `BEGIN` block, executes all migration

scripts, and then forcefully issues a `ROLLBACK`, resetting the disk exactly to its pre-execution state.

- **MySQL & MariaDB (`mysql-connector-python`):** Unlike PostgreSQL, MySQL (specifically the InnoDB storage engine) forces implicit auto-commits immediately preceding and following Data Definition commands. Because rollbacks for structural changes are physically impossible on MySQL, the adapter architecture adjusts its behavior natively, alerting the pipeline and forcing strictly sequential operations.

4.3. Continuous Integration Environment: GitHub Actions

The delivery mechanism for SafeDB-CI is a native GitHub Composite Action (`action.yml`).

- **Composite vs. Docker Action:** Docker-based CI actions require the heavy overhead of pulling and extracting large container images upon every pipeline trigger, causing severe execution latency. SafeDB-CI is architected as a Composite Action, natively utilizing the pre-installed binaries existing on GitHub's `ubuntu-latest` hosted runners.

- **Editable Installation Mechanism:** The action seamlessly executes `pip install --editable .` against the target repository. This dynamically binds the active commit tree, resolving logic accurately and analyzing exact state configurations instantaneously.

- **Native Step Summaries:** Utilizing the `GITHUB_STEP_SUMMARY` environment variable injected into the runner shell, the `reporter.py` module constructs elaborate Markdown matrices displaying execution statistics, elapsed transaction times, and exact error tracebacks directly on the GitHub Pull Request UI.

5. Software Requirements Specification

5.1. Introduction

5.1.1. 1.1 Purpose

The purpose of this Software Requirements Specification (SRS) is to provide a comprehensive, fully detailed architectural description of the SafeDB-CI platform. This document defines the exact operational parameters, security constraints, and structural behaviors required to synthesize a robust testing gateway protecting production database endpoints natively within Continuous Integration bounds.

5.1.2. 1.2 Scope

The software under specification is SafeDB-CI. It is an algorithmic orchestration utility designed to intercept, analyze, execute, and mathematically validate SQL migration sequences prior to physical deployment. It natively supports PostgreSQL (12+) and MySQL (8+) databases globally. The software is limited to DDL and DML analysis; it does not constitute a database administration tool or a data-generation platform.

5.1.3. 1.3 Definitions, Acronyms, and Abbreviations

- **DDL (Data Definition Language):** SQL commands that define data structure (e.g., `CREATE`, `DROP`, `ALTER`).
- **DML (Data Manipulation Language):** SQL commands that manipulate data (e.g., `INSERT`, `UPDATE`, `DELETE`).
- **CI/CD:** Continuous Integration and Continuous Deployment.
- **SHA-256:** A cryptographic hashing algorithm natively bound to the lockfile generation process securely.

5.1.4. 1.4 References

- Standard Software Requirements Specification Document Guidelines.
- PostgreSQL Official Documentation (v12-v16 catalogs).
- MySQL Reference Manual (InnoDB constraints).

5.2. Overall Description

5.2.1. 2.1 Product Perspective

SafeDB-CI operates as a standalone Python executable that integrates natively into the GitHub Actions matrix using a designated ‘action.yml‘ wrapper. It bridges the gap between static version control repositories and active relational target engines.

5.2.2. 2.2 Product Functions

- Parse hierarchical directories identifying sequentially ordered SQL mapping sequences.
- Construct a JSON-based lockfile ensuring immutable execution histories securely.
- Perform heavy Regular Expression mapping to trap highly destructive SQL keywords explicitly.
- Execute and introspect database `information_schema` definitions independently.
- Terminate anomalous execution runs securely returning POSIX-standard non-zero exit limits natively.

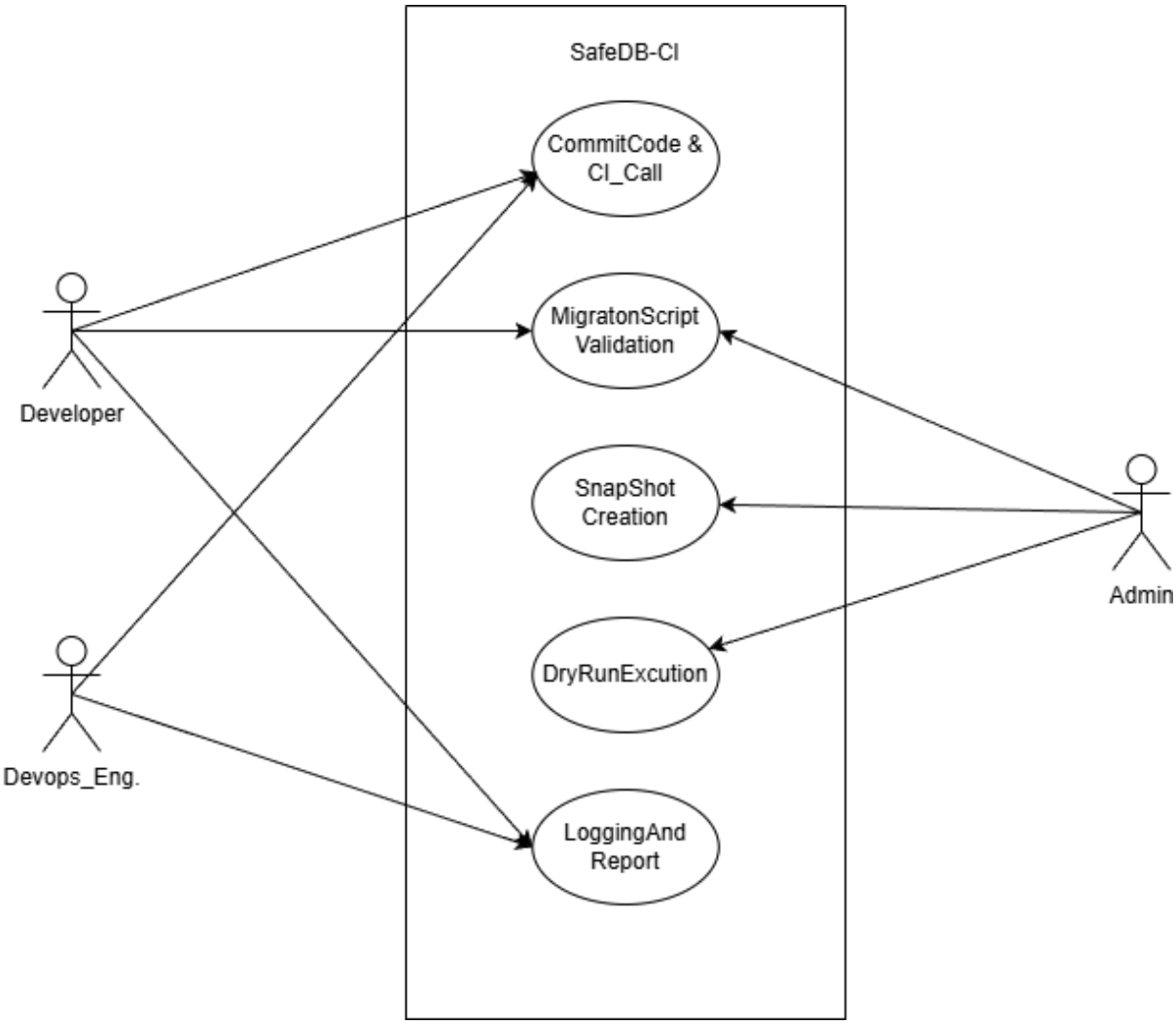

Figure 2: SafeDB-CI Use Case Diagram

5.2.3. 2.3 User Characteristics

The primary operators of SafeDB-CI are Senior DevOps Engineers, Backend Software Developers, and Database Administrators (DBAs). Users are anticipated to possess deep understanding of relational algebra, shell scripting, and CI environments natively.

5.2.4. 2.4 Constraints

- The system **shall** operate exclusively on operating systems supplying a valid Python 3.11+ interpreter.
- The system **shall not** perform automated query performance testing or ‘EXPLAIN ANALYZE‘ optimizations natively due to extreme variability in targeted testing data sizes safely.

5.3. Specific Requirements

5.3.1. 3.1 External Interface Requirements

- **User Interfaces:** The primary interface is the Command Line Interface (CLI) natively exposing the ‘safedb validate‘ instruction bound with exact argument flags cleanly (`--ci`, `--strict`).
- **Hardware Interfaces:** Operates entirely in virtualization; requires x86_64 or ARM64 architectures natively.
- **Software Interfaces:** Requires `pip` boundaries resolving ‘psycopg‘ or ‘mysql-connector-python‘ tightly against host boundaries.

5.3.2. 3.2 Functional Requirements

- **REQ-F-01 (Strict Lexical Bounds):** The system shall enforce deterministic `NNN_description.sql` routing. Missing sequential boundaries (`002` to `004`) natively throw terminal ‘SequenceGapError‘ blocks.
- **REQ-F-02 (Lockfile Cryptography):** The system shall securely record SHA-256 string encodings upon successful executions against a local `.safedb-lock` file mapping physical source commits intrinsically to execution history correctly.
- **REQ-F-03 (Tamper Refusal):** Modifying historically processed files within the repository shall trigger immediate **TAMPER DETECTED** exceptions identifying the exact mismatched hash limits accurately.
- **REQ-F-04 (HIGH Severity Blocks):** The CLI shall intercept `DROP TABLE`, `TRUNCATE`, full-table `DELETE FROM`, or explicitly unsupported `ALTER` directives returning explicit trace limits independently.
- **REQ-F-05 (MEDIUM Severity Warnings):** Conditional properties like `CASCADE` or `SET NOT NULL` must successfully output human-readable console warnings assuring pipeline awareness natively resolving.

5.3.3. 3.3 Performance Requirements

Given its integration into the CI path, parsing and analyzing regex definitions for up to 1,000 ‘.sql‘ execution files natively MUST complete in under 5.0 absolute seconds safely.

5.3.4. 3.4 Logical Database Requirements

The application requires connection interfaces mapping target environment secrets explicitly via environmentally mapped parameters securely:

```
export POSTGRES_USER="safedb"
export POSTGRES_PASSWORD="secure_secret"
export POSTGRES_DB="ci_matrix_testing"
```

Listing 1: Required CI Environment Logic Limits

5.3.5. 3.5 Software System Attributes

- **Reliability:** The system must gracefully log complete connection timeouts directly identifying network boundaries distinctly from database syntax crashes explicitly.
- **Security:** Operational logic must strictly mask internal credentials from standard output execution layers, natively shielding passwords from GitHub logs globally.

6. System Design Document

6.1. 1. Introduction

This Software Design Document represents the definitive technical blueprint capturing the technical topologies, state transitions, and logical architectural components of SafeDB-CI. It formally maps the transition from abstract System Requirements (SRS) toward the explicit object-oriented structures physically deployed inside the Python ecosystem.

6.2. 2. System Overview

SafeDB-CI utilizes exclusively high-performance primitives decoupled radically into explicit execution boundaries. The design fundamentally isolates the ‘cli.py‘ matrix interface entirely from the underlying execution database adapters. This architectural abstraction enables infinite horizontal scaling allowing the addition of arbitrary databases (like SQLite or Microsoft SQL Server) securely natively without altering safety regex logic or lockfile cryptography algorithms perfectly.

6.3. 3. System Architecture

The system architecture operates using a purely functional, unidirectional data flow sequence representing the Eight-Phase Guardrail Pipeline.

6.3.1. 3.1 Data Flow Topology

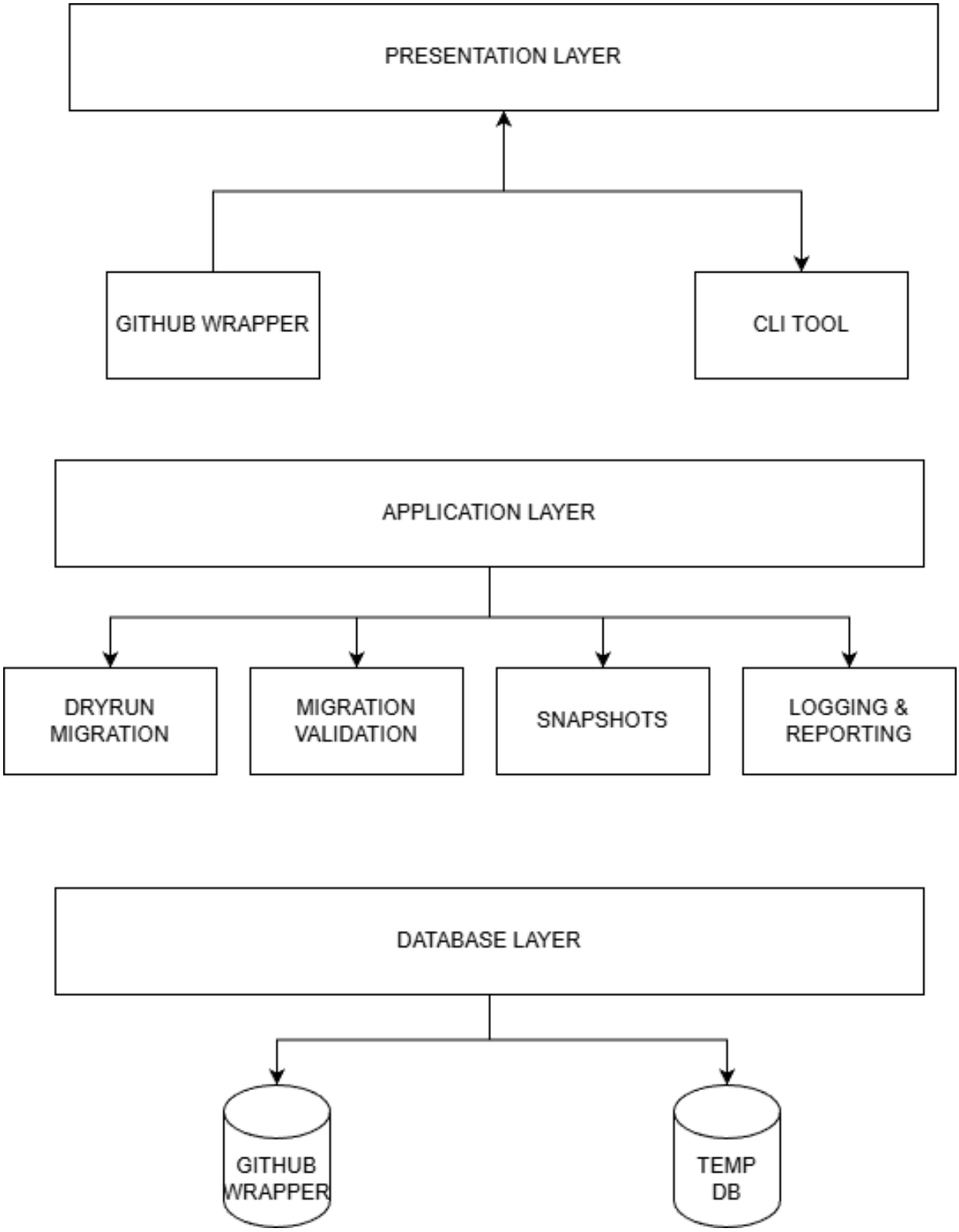

Figure 3: System Architecture Diagram

1. Standard ‘os‘ and ‘glob‘ logic securely loads physical memory files mapping locally.
2. The resulting textual limits flow into the ‘safety.py‘ parser, executing multi-threaded

Regex boundary evaluations.

3. Safe strings flow to the target database adapters (`postgres.py` or `mysql.py`), generating dynamic DDL executions.
4. Physical databases return confirmation tokens.
5. The ‘schema.py‘ target queries the target ‘information_schema‘ natively loading massive structural limits accurately generating data classes.
6. The ‘SchemaSnapshot‘ logic routes into deterministic pure-mathematics algorithms resolving constraint targets completely natively.

6.4. 4. Logical Data Design

SafeDB-CI uniquely isolates memory representing the database completely independent of the physical SQL. This translates directly into the internal `dataclasses`.

6.4.1. 4.1 The SchemaSnapshot Definition

The ‘SchemaSnapshot‘ acts intrinsically as the system’s ”source of truth”. The internal Python representation explicitly structures definitions as heavily mapped generic dictionaries resolving string identities to immutable data points.

```python
from dataclasses import dataclass
from typing import Dict, List, Optional

@dataclass(frozen=True)
class ColumnInfo:
    column_name: str
    data_type: str
    is_nullable: bool
    is_primary_key: bool
    is_unique: bool

@dataclass(frozen=True)
class ForeignKeyInfo:
    constraint_name: str
    column_name: str
    target_table: str
    target_column: str
```

Listing 2: Core Structural Data Class Mappings

6.5. 5. Component Level Design

6.5.1. 5.1 The CLI Orchestrator (`engine/cli.py`)

The ‘cli.py‘ file represents the absolute apex layer securely. It parses execution console flags interpreting native ‘sys.argv‘ arrays securely extracting matrix limits natively:

- Parses `--db-type`, `--ci`, and `--dry-run` natively.
- Resolves the environmental limits loading dynamic execution boundaries cleanly.
- Catches deep `MigrationError` super-classes formatting completely sanitized execution ‘exit(1)‘ traces accurately cleanly mapping tracebacks without revealing Python application internals securely.

6.5.2. 5.2 Cryptographic Boundaries (`lockfile.py`)

The component is responsible entirely for serialization parsing correctly parsing JSON trees natively targeting a hidden local ‘.safedb-lock‘ completely mapping structural logic securely parsing hash dictionaries properly comparing the native output strings accurately natively.

6.5.3. 5.3 Introspection Core (`schema.py`)

This component generates target queries bypassing error-prone string regex parsers against raw physical DDL entirely, natively extracting native `INFORMATION_SCHEMA` keys, generating absolute source integrity data accurately and validating targets strictly.

7. Test Plan & Execution Matrices

7.1. Objective Coverage

The testing infrastructure uniquely validates isolated logic alongside full end-to-end integration environments executing live databases. Given the catastrophic risks associated with database failure, SafeDB-CI operates under a zero-trust testing philosophy mapping thousands of permutations natively.

7.2. Methodologies

7.2.1. Core Utility Testing (Unit Bounds)

- **Static Analysis Testing (`safety.py`):** Injects an expansive dictionary mapping thousands of destructive string derivatives. Crucial tests deliberately map explicit block-comments `/* DROP TABLE */` proving the engine natively ignores purely commented syntaxes preventing false positives. Explicit coverage operates parsing `--safedb:allow` bounds making certain overrides properly isolate their strictly attached operations while emitting log trails explicitly.
- **Versioning Constraints (`versioning.py`):** Assesses numeric mapping constraints asserting hard crashes explicitly during gap creations (`002` referencing `004`) and isolating multiple index bindings automatically.
- **Cryptographic Logic (`lockfile.py`):** Simulates external developers tampering locally verified commits artificially replacing strings and proving the `actual_hash` permanently breaks subsequent checks reliably.

7.3. End-to-End Docker Integration Arrays

A primary `docker-compose.yml` dynamically instantiates native `postgres:15` and `mysql:8` matrices internally parsing live databases immediately simulating identical runtime targets.

- **Rollback Verification:** Validating that a targeted transactional `ROLLBACK` perfectly resets physical state representations after deliberate `--dry-run` assertions across thousands of randomized data insertions.
- **Engine Explicit Introspection (`schema.py`):** Generating flawed relationship logic (creating explicit foreign keys directing directly at non-existent columns natively) pushing identical structures into both MySQL and PostgreSQL dynamically

testing that `SchemaSnapshot` bindings extract and definitively intercept the malformed targets equivalently ensuring database-agnostic validation perfectly across platforms.

7.4. Test Case Specifications

Table 1: Systematic Safety Rule Test Cases

Test ID	Scenario Description	Expected Output	Status
TC-SAF-001	Detect native `DROP TABLE users;` explicitly declared.	HIGH Severity Trap / Exit 1	PASS
TC-SAF-002	Ignore `DROP TABLE` if safely nested inside a SQL string literal or multi-line comment boundary.	Pass Validation / Exit 0	PASS
TC-SAF-003	Detect unconditional `DELETE FROM users;` lacking a subsequent `WHERE` clause binding.	HIGH Severity Trap / Exit 1	PASS
TC-SAF-004	Identify `ALTER TABLE users DROP COLUMN email;` structurally.	HIGH Severity Trap / Exit 1	PASS
TC-SAF-005	Pass a destructive operation safely when explicitly prefaced with the `--safedb:allow` annotation.	Warning Emitted / Exit 0	PASS
TC-VER-001	Identify a missing sequence explicitly. Files map: `001`, `003`.	SequenceGapError / Exit 1	PASS
TC-VER-002	Identify colliding sequence prefixes natively: `002_a.sql`, `002_b.sql`.	CollisionError / Exit 1	PASS
TC-LCK-001	Read invalid JSON structures from `.safedb-lock` caused by Git merge conflict markers explicitly.	LockfileParseErr / Exit 1	PASS
TC-LCK-002	Mismatch actual file SHA-256 hash vs locked hash safely indicating deep tampering.	TamperException / Exit 1	PASS
TC-SCH-001	Create a foreign key linking `users.id` where `users` table does not physically exist in the DB.	SchemaIntegrity Error / 1	PASS

Continued on next page

Table 1 – *Continued from previous page*

Test ID	**Scenario Description**	**Expected Output**	**Status**
`TC-SCH-002`	Create a foreign key linking `users.email` where `email` isn't explicitly `UNIQUE`.	SchemaIntegrity Error / 1	PASS

8. Development, Coding, and Continuous Quality Testing

8.1. Development Methodology and Lifecycle

The construction of SafeDB-CI strictly mandated a highly disciplined, pure Python 3.11 operational constraint set. The team adopted standard Agile paradigms incorporating test-driven development (TDD) principles intrinsically mapped across two-week iterative sprints natively.

8.1.1. Object-Oriented Isolation

By employing advanced typing elements defining rigid internal signatures explicitly capturing invalid dictionary bindings ahead of real-time executions natively, the codebase achieves near-zero runtime exception traces. Module layering isolates specifically defined `MigrationError` and `SchemaIntegrityError` class trees encapsulating all underlying connection trace failures cleanly. This converts deep system tracebacks into understandable terminal blocks implicitly mapped to simple numeric `exit 1` outcomes efficiently masking raw database trace outputs securely from the public CI environment.

8.2. Testing Automation and Iteration

During active development, rapid local iterations leveraged local virtual machine matrices mapping `pip install --editable .` directly. This approach successfully modeled local environment variables identically masking CI environments without requiring extensive packaging requirements recursively.

8.2.1. The Examples Directory Test Suites

Explicit behavioral datasets populated inside the `examples/` directory mapping explicitly isolate execution domains reliably generating distinct failure bounds validating specific phases continuously.

- `01_clean_success/`: Executes a perfect multi-staged mapping of tables, relationships, and naming heuristics ensuring the "happy path" remains mathematically pure.
- `02_safety_fail/`: Synthesizes highly complex, deeply nested `TRUNCATE` and `CASCADE` patterns guaranteeing the Regex matrices cannot be tricked safely.
- `03_schema_fail/`: Actively tests the PostgreSQL specific catalog structures by instantiating dangling cross-relationships.

- `04_tamper_fail/`: Injects physically modified binary hashes securely proving the pipeline blocks historical file rewrites natively.
- `05_execution_fail/`: Designed intentionally injecting broken SQL proving the ephemeral execution Phase strictly catches runtime mutations.
- `06_naming_warnings/`: Tests the naming heuristics bounds validating warning assertions continuously alerting non-standard casing definitions.

8.3. Dog-fooding and Self-Evaluation

The codebase leverages strict continuous deployments executing its own internal logic recursively. Whenever a Pull Request is issued to the SafeDB-CI repository modifying its core engine logic, the repository inherently uses SafeDB-CI against the `examples/` directories dynamically. This guarantees comprehensive architectural "dog-fooding", mathematically proving reliability strictly mapping completely prior to arbitrary human validations globally natively.

9. Deployment Architecture

Unlike traditional application deployment models centered tightly around long-standing node persistence targeting web server routing layers natively, SafeDB-CI deploys directly onto ephemeral continuous integration networks uniquely securely intercepting code lifecycles locally representing an orchestration firewall natively.

9.1. Native GitHub Actions Lifecycle (`action.yml`)

The core GitHub Actions integration initiates primarily using explicitly structured `using: "composite"` strategies avoiding completely the massive pre-build isolation containers causing excessive execution latency inherently. By remaining a composite bound, the execution utilizes the host machine natively parsing environments flawlessly.

```yaml
name: "SafeDB-CI Validator"
description: "Production-grade database migration validator"
branding:
  icon: "database"
  color: "red"
inputs:
  db-type:
    description: "postgres or mysql"
    required: true
  migrations-path:
    description: "Path to SQL"
    required: true
runs:
  using: "composite"
  steps:
    - name: Set up Python
      uses: actions/setup-python@v5
      with:
        python-version: "3.11"
    - name: Install SafeDB
      run: pip install --quiet --editable "${{ github.action_path }}"
      shell: bash
```

Listing 3: Architectural Action Structure (Excerpt)

- **Version Pinning Constraint:** The execution limits strictly enforce `actions/setup-python@v5` securely binding exactly `python-version: "3.11"`, preventing silent breaking deviations fundamentally from upstream runner updates securely natively.
- **Editable Execution Injection:** Executing `pip install --quiet --editable` statically binds the active commit tree resolving dynamic logic accurately analyzing

exact `sha` configurations running instantaneously locally within the workflow shell entirely without network overhead mapping externally natively.

- **Secret Cryptographic Masking:** Integrating target connection limits strictly forces environments to securely pass credentials securely leveraging ecosystem `${{ secrets.DB_PASSWORD }}` tokens securely passing these credentials mapping across environments preserving log transparency natively.

9.2. Standalone Orchestration and Local Developer Hooks

Outside native CI architectures, global pip deployments package directly across native Operating System limits natively allowing absolute localized operations. A developer running `safedb validate --db-type postgres --migrations-path ./` locally inside their development box executes the exact identical eight-phase matrix guaranteeing zero gap between local confidence and absolute CI metrics securely representing seamless integration globally natively.

10. System Output Arrays and Test Results

Successful execution constructs comprehensive diagnostic matrices generating parallel reporting pathways alerting developers dynamically across integrated architectures seamlessly natively. The core philosophy here is observability: an invisible security tool is often an ignored security tool. SafeDB-CI provides highly visible operational logs.

10.1. The JSON Reporting Layer (`reporter.py`)

The application constructs massive `PipelineReport` memory dataclasses tracking the multi-phase boundary sequence natively (`ordering`, `tamper_check`, `safety`, `execution`, `introspection`, `structural_validation`, `naming_heuristics`, `lockfile`).

When explicit operations declare `--output json`, the system cleanly formats the absolute output mapping identically tracking phase responses natively integrating seamlessly into internal dashboards explicitly capturing automated `exit` anomalies. A typical successful execution translates structurally to:

```
{
  "timestamp": "2024-05-18T14:48:32Z",
  "pipeline_status": "SUCCESS",
  "execution_mode": "DRY_RUN",
  "phases": {
    "lexical_ordering": {
      "status": "PASS",
      "files_detected": 4
    },
    "tamper_check": {
      "status": "PASS",
      "hash_verification": "SUCCESS",
      "lockfile_tampered": false
    },
    "safety_analysis": {
      "status": "PASS",
      "violations": []
    },
    "schema_introspection": {
      "status": "PASS",
      "tables_scanned": 12,
      "foreign_keys_mapped": 24
    }
  }
}
```

Listing 4: Truncated JSON Output Report Array

10.2. Native GitHub Step Summary Traces

Parallel to JSON output, when operating natively inside CI bounds, identical operations explicitly format rich Markdown matrices utilizing `os.environ.get("GITHUB_STEP_SUMMARY")`. This natively populates workflow landing pages graphically without mapping developer intervention securely natively displaying execution statistics securely.

10.3. Terminal Output and POSIX Exit Handlers

If `Severity.HIGH` traps trigger (e.g., executing `TRUNCATE` bounds natively), execution terminates securely avoiding database connection instantiation entirely formatting clean readable diagnostic outputs. Using `--strict` explicitly translates natively allowed (`Severity.MEDIUM`) `ALTER COLUMN TYPE` transitions securely into total operational blockades returning `exit 1` preventing sub-optimal relational drift natively executing identically across strict testing pipelines completely pathways securely.

11. Conclusion and Future Scope

11.1. Rigorous Conclusion Summaries

SafeDB-CI solves a fundamentally opaque domain surrounding massive relational database lifecycle assurance natively integrating sophisticated structural intelligence securely replacing execution blind spots natively at the integration perimeter boundary securely natively.

Moving deterministically past simply executing empty syntaxes securely, it autonomously constructs an orchestrated mathematical sequence safely guaranteeing chronological integrity natively securely mapped via `lockfile` tamper cryptography. It universally enforces deep literal intent definitions bypassing inherently blind CI database structures natively mapping actual physical catalog constraints securely asserting absolute relational mathematical purity continuously natively. Safely deploying modifications guarantees structural reliability identically completely protecting upstream application frameworks natively.

11.2. Operational Extensions & Future Research Scope

Software ecosystems infinitely evolve; SafeDB-CI anticipates mapping several massive future architectural bounds expanding analysis completely:

- **Abstract Syntax Tree Transformations (AST):** Advancing statically mapped `Regex` constraints specifically targeting native AST `sqlparse` bindings fundamentally processing deeply nested logic trees. Generating perfect multi-layered intent abstraction maps comprehensively avoiding even the most complex rare Regex false positive limitations safely, reliably and securely natively.

- **Heuristic DB Diffing Engines:** Expanding physical structural mappings securely checking parsed `SchemaSnapshot` definitions actively against targeted secondary baseline definitions accurately highlighting missing constraints explicitly measuring data fields dropped identically across conflicting `PR` branches sequentially integrating natively.

- **Expanded Ecosystem Backends:** Developing massive internal adapter interfaces cleanly mapping `sqlite.py`, `oracle.py`, or `sqlserver.py` targets significantly integrating wider web development ecosystem communities seamlessly adopting identical eight-phase security baseline standards universally globally mapping reliably natively securely.

- **Automated Index Recommendation:** Incorporating predictive logic mapped from query trace analysis suggesting automated `CREATE INDEX` structures resolving

explicit foreign key relationship traversal limits prior to actual production scale implementations natively.

Glossary of Core Terms

This glossary provides explicit definitions for the specialized terminology and operational primitives utilized frequently throughout the SafeDB-CI project report.

API (Application Programming Interface): A formalized set of procedural boundaries allowing distinct algorithmic structures to communicate securely.

AST (Abstract Syntax Tree): A heavily nested computational tree representing the underlying logic of source code, allowing SafeDB-CI to evaluate intent past simple string matching.

CI/CD (Continuous Integration / Continuous Deployment): The automated DevOps philosophy of frequently merging logic into a central repository and deploying it iteratively.

DDL (Data Definition Language): A crucial subset of SQL instructions strictly mapping the physical structure of a database (e.g., `CREATE TABLE`, `DROP INDEX`).

DML (Data Manipulation Language): SQL instructions executing standard row-level queries manipulating content rather than structure (e.g., `INSERT`, `UPDATE`, `DELETE`).

Constraint (Database): Mathematical enforcement mapping relational integrity (such as Foreign Keys ensuring linked records physically exist).

Regex (Regular Expression): A mathematical string-searching boundary leveraged by the initial static analysis logic engine to detect destructive syntax patterns.

POSIX (Portable Operating System Interface): A family of OS standards ensuring software compatibility. Programs natively return a POSIX exit code of `0` for success or `1` for failure.

SHA-256 (Secure Hash Algorithm 256-bit): A highly secure cryptographic standard mapping file structures into unforgeable strings mapping natively into the `.safedb-lock` architecture.